NetMon Security Audit 2026 - Runde 13

Version: 1.1.22

Großes Security-Audit: 85 Findings, Vorgehensweise, Fixes und Verifikation für NetMon Roots.

Inhaltsverzeichnis

NetMon Security Audit 2026 - Runde 13

NetMon Security Audit 2026 - Runde 13 (Großes Security-Audit)

- Kurzurteil
- Umfang
- Vorgehensweise
- Beteiligte Werkzeuge und Modelle
- Findings und Fixes - Hoch
- Findings und Fixes - Mittel
- Findings und Fixes - Niedrig
- Bewusst akzeptierte Restrisiken
- Querschnitts-Härtungen
- Verifikation
- Prüfgrenzen
- Offene Empfehlungen
- Einordnung

NetMon Security Audit 2026 - Runde 13

Quelle: docs/SECURITY_AUDIT_2026_R13.md

NetMon Security Audit 2026 - Runde 13 (Großes Security-Audit)

Kurzurteil

Analysierter Stand: NetMon 1.1.22 (Repository Noogman4/dev-lab), Fixes bis Commit 9f788603 vom 13. November 2026.

Ergebnis: Alle 85 Findings aus den Repository-Scans vom 17. Oktober bis 13. November 2026 sind bearbeitet. 82 sind behoben und durch Regressionstests abgesichert, 3 sind nach Prüfung bewusst als Restrisiko akzeptiert und begründet. Es ist kein Finding offen, insbesondere keines der Stufe Hoch.

Schweregrad	Gemeldet	Behoben	Akzeptiert (Won't fix)	Offen
Hoch	11	11	0	0
Mittel	38	36	2	0
Niedrig	36	35	1	0
Gesamt	85	82	3	0

Diese Runde unterscheidet sich von den bisherigen: Sie fasst nicht ein einzelnes Delta zusammen, sondern den kompletten Befundbestand eines knapp vierwöchigen Scan-Zyklus über Anwendung, Paketierung, Release-Kette und Website.

Umfang

- Desktop-Anwendung NetMon Roots: privilegierte Pfade (sudo, UFW, WireGuard, NetworkManager, HDD, Swap, Nmap, rkhunter, FreshClam), Killswitch und VPN-Prüfungen.
- Importe und Parser: Text, PDF, DOCX, CSV, XLSX, Bilder, WireGuard-Profile, Linux-Hilfe-Kataloge.
- Netzwerkzugriffe: Radio-Verzeichnisse und Streams, projectM, Update-Metadaten, Icons, OpenAI-API, öffentliche IP- und Länderabfragen.
- Logs, Diagnose und Datenschutz: Logrechte, Support-Bundle, Schwärzung von Zugangsdaten vor KI-Übergabe.
- Download-Scan und ClamAV: Vor-Quarantäne, Scan, Freigabe, Quarantäne.
- Release-Kette: DEB-Build, Release-Receipts, Signatur, Bundles, Restore.
- Website: PHP-Download-Statistik, Caddy-/Entwicklungsserver.

Nicht enthalten: externer Penetrationstest, Prüfung des Live-Hostings, dynamisches Fuzzing, Sicherheitslage der vom Betriebssystem gelieferten Programme.

Vorgehensweise

1. Automatisierte Repository-Scans durch Defense Factory; jedes Finding mit Datenfluss, Angreifermodell, Vorbedingungen und Schweregrad. Letzter Scan: 6f2c6130 auf Commit 938c3eb (13.11.2026).
2. Manuelle Nachprüfung jedes Findings am aktuellen Code statt am Scan-Stand: Ist die Stelle erreichbar, ist das Angreifermodell realistisch, stimmt der Schweregrad?

3. Wo sinnvoll Reproduktion mit synthetischen Daten, zum Beispiel Symlink auf /dev/zero und FIFO beim Import, Löschen über einen Symlink-Pfad, Speichermessung eines endlosen curl-Stroms, Fälschen einer Bericht-Datei per Symlink.

4. Entscheidung durch den Maintainer: beheben oder begründet als Restrisiko akzeptieren.

5. Kleine, nachvollziehbare Fixes mit Regressionstests. Für die Fixes vom 13.11. zusätzlich eine Gegenprobe: Die neuen Tests wurden gegen den Code vor dem Fix ausgeführt (alte Module nur im Speicher eingesetzt) und müssen dort fehlschlagen.

6. Qualitätsprüfung mit black (einzeln pro Datei), ruff und gezielten pytest-Läufen; Fehlerlisten vor und nach dem Fix verglichen, damit Umgebungsfehler nicht als Regression gelten.

7. Commits enthalten nur die eigenen Änderungen; parallele, nicht committete Arbeiten im gemeinsamen Arbeitsbaum blieben unberührt.

Beteiligte Werkzeuge und Modelle

- Scanner: Defense Factory (Repository-Scans; Quelle aller 85 Findings im Dashboard).
- Analyse und Umsetzung: Claude Opus 5.5 (claude-opus-5-5) in Claude Code. In 34 Commits vom 11. bis 13.11. als Co-Autor ausgewiesen.
- Weitere Fixes aus früheren Arbeitssitzungen des Maintainers (Commits ohne Co-Autor-Angabe), die zugehörigen Detailberichte liegen unter docs/security/.
- Prüfwerkzeuge: pytest, black, ruff, curl 8.5 für Transporttests.
- Verantwortung und Freigabe: Maintainer Sven Fröhlich.

Findings und Fixes - Hoch

- H-01 (12.11.) Produktions-Build konnte uncommittete Inhalte und Tooling signieren. Fix: Bundles entstehen nur aus einem exportierten Snapshot des gepinnten Commits; jede Abweichung im Arbeitsbaum bricht ab. Commit b983b6d0.
- H-02 (12.11.) Ein gefälschter Release-Receipt ließ den Signierer eine fremde DEB authentifizieren. Fix: Die DEB wird im Commit-Snapshot selbst gebaut und signiert, dist/ wird nicht mehr gelesen. Commit e8084e00.
- H-03 (12.11.) Privilegierte Nmap-Presets konnten einen untergeschobenen PATH-Wrapper als root starten. Fix: Start nur über feste Systempfade. Commit 55af9fc9.
- H-04 (12.11.) Eine freigegebene DEB konnte vor dem Signieren der Hashes ausgetauscht werden. Fix: Signierte Bundles sind an den im Receipt freigegebenen DEB-Hash gebunden. Commit 0d8ae962.
- H-05 (12.11.) Release-Builder signierten Bytes hinter Symlinks im Arbeitsbaum. Fix: Symlinks beim Staging der Produktionseingaben werden abgelehnt. Commit 81779a93.
- H-06 (12.11.) Vor-Quarantäne-Fallback erlaubte Symlink-Überschreiben und Austausch geprüfter Dateien. Fix: Import ohne Symlinks, Freigabe nur der tatsächlich gescannten Datei, Mount nur an einem festen root-eigenen Punkt. Commits 621fb61d, c12b5034.
- H-07 (11.11.) Der privilegierte FreshClam-Fallback las eine benutzerkontrollierte Konfiguration. Fix: Benutzerkonfiguration bleibt aus dem sudo-Fallback heraus. Commit 2e434b57.
- H-08 (11.11.) PATH-Einträge mit Traversal umgingen die rkhunter-WEB_CMD-Prüfung. Fix: WEB_CMD nur noch auf geschützte System-Downloader. Commit 604c5c06.

- H-09 (11.11.) PATH-aufgelöstes sudo konnte das in NetMon eingegebene Admin-Passwort abgreifen. Fix: sudo nur über einen vertrauenswürdigen Systempfad, auch für Wartungs-, Radio- und HDD-Pfade. Commits 216e32b4, 04e31592, 272cece0.
- H-10 (17.10.) Der Signaturprüfer erzwang den gepinnten Public Key nicht standardmäßig. Fix: Gepinnter Schlüssel ist Standard. Commit bfaacf11.
- H-11 (17.10.) Restore-Skripte entpackten Archivmitglieder ungeprüft unter der Restore-Wurzel. Fix: Authentifizierte Manifeste und Pfadrichtlinien beim Restore. Commit 5d7c2a31.

Findings und Fixes - Mittel

- M-01 (13.11.) Konkurrierende UFW-Änderungen konnten eine bestätigte Regellöschung auf eine andere Regel umlenken. Fix: Status lesen, zuordnen und löschen in einem Lock-Bereich; die SSH-Bereinigung löst Regelnummern vor jeder Löschung neu auf. Commit 94972b6d.
- M-02 (13.11.) Die SSH-Bereinigung löschte fremde Regeln, die irgendwo „22“ enthielten. Fix: Erkennung über den strukturierten UFW-Parser (nur eingehend ALLOW/LIMIT auf Port 22 oder OpenSSH), Mehrfachports werden nur gemeldet, der Dialog zeigt die exakten Regeln. Commit 4db82fa1.
- M-03 (13.11.) Ein präpariertes VPN-Profil konnte eine andere WireGuard-Datei löschen. Akzeptiert, siehe Abschnitt Restrisiken.
- M-04 (13.11.) Die Diagnose-Analyse konnte Zugangsdaten an die KI-API senden. Fix: Gemeinsamer Schwärzungsfilter für Chad, zusätzliche Schwärzung direkt vor dem API-Aufruf, Vorschau gleich Anfrage. Commit 60e4f1c3.
- M-05 (13.11.) Die Backup-Prüfung meldete Erfolg ohne Dateiprüfung. Fix: Der nicht erreichbare eingebaute Backup-Code wurde entfernt; Datensicherung läuft über die Desktop-Werkzeuge. Commit 295af74a.
- M-06 (13.11.) Wartungsaktionen der Vor-Quarantäne konnten außerhalb des Ordners löschen oder Dateien kürzen. Fix: Leeren nur im privaten Ordner per Verzeichnis-Deskriptor und mit Bestätigung; Berichte exklusiv und außerhalb der Vor-Quarantäne. Commit b1e0cec4.
- M-07 (13.11.) Der Text-Import las ausgetauschte oder endlose Objekte (Symlink, FIFO, Gerät). Fix: Genau ein begrenzter Lesevorgang ohne Symlinks, nur reguläre Dateien bis 5 MiB. Commit 48b4ca59.
- M-08 (13.11.) Automatische Netzprüfungen puffern curl-Ausgaben unbegrenzt. Akzeptiert, siehe Restrisiken; die IP- und Länderabfragen sind zusätzlich auf 4 KiB gedeckelt (9f788603).
- M-09 (13.11.) Die Prüfung des VPN-Austrittslands ließ sich fälschen. Fix: Abfragen nur per HTTPS, auch bei Weiterleitungen; die IP-Antwort wird als Adresse validiert. Commit 9f788603.
- M-10 (13.11.) Sender-Metadaten konnten den Standardbrowser zu privaten Diensten lenken. Fix: Browser-Übergabe für Sender-Homepages entfernt. Commit 24eba8d0.
- M-11 (13.11.) Ein Zeilenumbruch im Scan-Pfad konnte einen ClamAV-Fund für eine fremde Datei fälschen. Fix: Funde sind an die Identität der gescannten Datei gebunden. Commit a3b97c66.
- M-12 (12.11.) Ein präpariertes PDF konnte NetMon vor dem Kürzen erschöpfen. Fix: PDF-Parsing nur in einem begrenzten Worker-Prozess. Commit 81bddb95.
- M-13 (12.11.) Eine kollidierende WireGuard-Datei ersetzte still ein root-Profil. Fix: Ersetzen nur mit bestätigtem Digest. Commit 6d3a9b99.
- M-14 (12.11.) Der Paketmitschnitt hatte keine harte Größengrenze. Fix: Größenlimit und Freiplatzreserve. Commit 8ef4715a.

- M-15 (12.11.) Der Firefox-Runtime-Download überschritt seine Gesamtfrist und fror die Oberfläche ein. Fix: Harte Gesamtfrist, Oberfläche bleibt bedienbar. Commit c94ef1e0.
- M-16 (12.11.) Die Swap-Größenänderung schrieb als root über einen austauschbaren Pfad. Fix: Änderung über fixierte Deskriptoren in einem einzigen root-Prozess. Commit 28725046.
- M-17 (12.11.) Eine Update-URL bestand die Allowlist, öffnete aber einen anderen Origin. Fix: Browser-Übergabe an den vertrauenswürdigen HTTPS-Origin gepinnt. Commit b26b9674.
- M-18 (12.11.) Ein per PATH gewähltes nmcli bestimmte das als root geänderte Profil. Fix: nmcli nur über den Systempfad. Commit fc4fb2a6.
- M-19 (12.11.) Der Upload-Baum konnte vom authentifizierten Release-ZIP abweichen. Fix: Upload-Bäume werden aus dem authentifizierten ZIP rekonstruiert. Commit 91ab0fc1.
- M-20 (12.11.) Der Radio-Zustand nutzte unsichere XDG-Verzeichnisse und folgte Symlinks. Fix: Private Zustandsdateien und authentifizierte Übergaben. Commit 98468dd0.
- M-21 (11.11.) Importierte Linux-Hilfe-Kataloge konnten die Bestätigung für Shellbefehle unterdrücken. Fix: Jeder Befehl wird vor dem Terminalstart bestätigt. Commit bac02d28.
- M-22 (11.11.) Der Produktions-Build konnte eine unbewiesene Test-DEB als Release signieren. Fix: Nur Receipt-gebundene DEBs aus dem aktuellen Commit. Commit 13581e3f.
- M-23 (21.10.) Signierte Release-Manifeste deckten den Website-Code nicht ab. Fix: Vollständige Bundle-Manifeste werden authentifiziert. Commit 58611ac5.
- M-24 (20.10.) Privilegierte Konfigurationsabläufe öffneten ersetzbare Temporärdateien erneut. Fix: Gehärtete privilegierte Schreibwege mit Rollback. Commit f63ffdfa.
- M-25 (20.10.) Der HDD-Slot-Zustand ließ root ein beliebiges Dateisystem-Image mounten. Fix: Gerätebindung der Slots bleibt erhalten und wird geprüft. Commits baecee92, c0fec095.
- M-26 (20.10.) Generierte Secure-Browser-Backups erbten zu offene Rechte. Fix: Rechte und Veröffentlichung abgesichert. Commit 400bc52b.
- M-27 (20.10.) Per PATH aufgelöste Privileg- und Disk-Werkzeuge konnten eingegebene Passwörter abgreifen. Fix: Vertrauenswürdige Systempfade für sudo und alle passworttragenden Pfade. Commits 216e32b4, 272cece0.
- M-28 (19.10.) Postinstall-Skripte folgten Symlinks im Benutzer-Home. Fix: Keine privilegierten Schreibzugriffe mehr ins Home. Commit 2eb1ed8f.
- M-29 (19.10.) Die HDD-Slot-Konfiguration erreichte einen uneingeschränkten root-Mount. Fix: fstab-Auflösung und Mount-Autorisierung gehärtet. Commit d69c3f26.
- M-30 (19.10.) Die Killswitch-Recovery schwächte eine bestehende UFW-Policy. Fix: Recovery schlägt sicher fehl statt zu öffnen. Commit edf4f32f.
- M-31 (19.10.) Ein manueller WireGuard-Endpoint erlaubte Zeilenumbrüche und damit Hook-Injektion. Fix: Endpoint-Injektion wird abgewiesen. Commit c73a0923.
- M-32 (19.10.) Importierte Profilnamen erzeugten breite UFW-Freigaben auf fremden Interfaces. Fix: Freigaben an verifizierte Interfaces gebunden. Commits 4a3b100d, 8f5dfe9d.
- M-33 (17.10.) Ungültiges UTF-8 konnte die Download-Statistik beschädigen. Fix: Atomare, UTF-8-sichere Speicherung. Commit cf9bbe16.
- M-34 (17.10.) Externe projectM-ZIPs hatten keine Download- und Entpackgrenzen. Fix: Begrenzte Downloads und Extraktion. Commits 3bb9882f, 1194bf5f.

- M-35 (17.10.) Das Secure-Browser-Inventar führte gefundene Container-Binaries aus. Fix: Keine ausführenden Proben mehr. Commit e93edf9f.
- M-36 (17.10.) Icon-Metadaten konnten Anfragen ins lokale oder private Netz lenken. Fix: Gesicherte Icon- und Metadaten-Downloads. Commit 0d0917d0.
- M-37 (17.10.) Unbegrenzte Quellen-Labels belasteten Speicher und CPU der Download-Statistik. Fix: Ressourcen der Statistik begrenzt. Commit 8afdfb04.
- M-38 (17.10.) Ein Unsigned-Opt-out erzeugte produktionsartige Release-Bundles. Fix: Signierte Produktions-Bundles werden erzwungen. Commit 2ba84481.

Findings und Fixes - Niedrig

- L-01 (13.11.) Ein kurzer NETMON_STATS_TOKEN wäre erratbar. Akzeptiert, siehe Restrisiken.
- L-02 (13.11.) Senderfelder konnten gefälschte Diagnose-Logeinträge erzeugen. Fix: Unvertrauenswürdige Metadaten bleiben in einem einzigen Logdatensatz. Commit 938c3ebc.
- L-03 (11.11.) DOCX-Importe wurden vor jeder Größengrenze vollständig entpackt. Fix: DOCX-Parsing isoliert mit strikten Grenzen. Commit b756e51d.
- L-04 (11.11.) Der Hash-Helfer griff bei präpariertem Manifest auf Pfade außerhalb seines Arbeitsbereichs zu. Fix: Prüfsummen-Manifeste nur für explizit gewählte Dateien. Commit beb530df.
- L-05 (11.11.) Sensible Logs entstanden mit Standardrechten und ohne Schwärzung. Fix: Rohdiagnosen werden geschwärzt, Bootstrap-Logs sind privat. Commit 5ab66368.
- L-06 (11.11.) Linux-Hilfe-Importe aus CSV und XLSX waren unbegrenzt. Fix: Begrenzter Import in einem ressourcenbeschränkten Worker. Commit 27790007.
- L-07 (11.11.) Weiterleitungen der Release-Metadaten konnten private Dienste erreichen. Fix: Nur der freigegebene öffentliche Origin. Commit bb47bfb6.
- L-08 (11.11.) ClamAV-Scans hatten keine wirksame Frist und unbegrenzte Ausgabe. Fix: Fristen, begrenzte Ausgabe, Aufräumen der Prozessgruppe. Commit ac41b8cf.
- L-09 (21.10.) Die Chad-DOCX-Größenprüfung begrenzte das Entpacken nicht. Fix: Dekompression vor dem Parsen begrenzt. Commit 14b4be43.
- L-10 (21.10.) Der privilegierte Uninstaller vertraute übernommenen Umgebungsvariablen. Fix: Ziele des Uninstallers eingeschränkt. Commit 74a2fbab.
- L-11 (21.10.) Eine Wildcard-Domain hob die Secure-Browser-Isolation auf. Fix: Globale Wildcards werden abgelehnt. Commit 233b1514.
- L-12 (21.10.) Radio-Stream-URLs erreichten Loopback- und private Dienste. Fix: Radio-Netzzugriffe nur noch über eine Prüfung auf öffentliche Ziele. Commit ff103749.
- L-13 (21.10.) Strukturierte Importe wurden ohne Ressourcengrenzen geparst. Fix: Begrenzung vor dem Parsen. Commit 0a916707.
- L-14 (21.10.) Die privilegierte Authentifizierung löste sudo über das geerbte PATH auf. Fix: Vertrauenswürdiger sudo-Pfad. Commit 216e32b4.
- L-15 (21.10.) Importierte WireGuard-Hooks liefen ohne Einzelprüfung als root. Fix: Hooks werden bei Import und privilegierter Ausführung abgewiesen. Commit ece3ad64.
- L-16 (21.10.) Diagnose-Logs hingen für ihre Vertraulichkeit von der umask ab. Fix: Private Logverzeichnisse und Dateirechte werden erzwungen. Commit fc0b02d9.

- L-17 (20.10.) Eine vorhersagbare Inventarausgabe im gemeinsamen Temp-Verzeichnis folgte Symlinks. Fix: Geschützte temporäre Ausgabe. Commit a797d4a2.
- L-18 (20.10.) Ein manipulierter HDD-Slot-Zustand konnte fremde interne Dateisysteme aushängen. Fix: Systemmounts geschützt, verifizierte Zustimmung zum Aushängen. Commit 0277d1c3.
- L-19 (20.10.) Sender-URLs aus Verzeichnissen konnten Verbindungen ins private Netz auslösen. Fix: Prüfung auf öffentliche Ziele für Radio-Zugriffe. Commit ff103749.
- L-20 (20.10.) Weiterleitungen von Radio-Verzeichnissen erreichten private Dienste. Fix: Weiterleitungen begrenzt und geprüft. Commit 6ee8c59e.
- L-21 (20.10.) Unbegrenzte ICY-Metadatenintervalle hielten Threads und Verbindungen. Fix: ICY-Anfragen begrenzt und abbrechbar. Commit 0c23fabd.
- L-22 (20.10.) OpenAI-Antworten wurden ohne Byte-Obergrenze gepuffert. Fix: Antwortgröße und Transportfristen begrenzt. Commit cf89d190.
- L-23 (20.10.) Die mitgelieferte Caddy-Konfiguration konnte PHP-Quelltext und Statistikdaten ausliefern. Fix: Öffentlicher Caddy-Export isoliert, sichere Rechte. Commit 7d6e3a6d.
- L-24 (20.10.) Versionsmetadaten wurden ohne Größen- und Zeitbudget gepuffert. Fix: Fristen für Metadatenanfragen. Commit 87dca862.
- L-25 (19.10.) VPN-Wechsel und -Abschalten bauten alle WireGuard-Interfaces des Hosts ab. Fix: Aufräumen nur eigener Interfaces. Commit feb340c3.
- L-26 (19.10.) Antworten von Radio-Verzeichnissen wurden ohne Byte-Grenze gelesen. Fix: Begrenzte Downloads. Commit 6ee8c59e.
- L-27 (19.10.) Die Secure-Browser-Wartung folgte beim Umschreiben Symlinks. Fix: Symlink-Umlenkung verhindert. Commit 8e2d8b17.
- L-28 (19.10.) Entwicklungs-Webserver gaben das Repository-Wurzelverzeichnis frei. Fix: Nur öffentliche statische Site-Dateien. Commit da967174.
- L-29 (19.10.) Weiterleitungen von projectM-Paketen erreichten Loopback- und private Dienste. Fix: Nicht-öffentliche Ziele blockiert. Commit 4dd6d29d.
- L-30 (17.10.) Über eine gemeinsame PID-Datei konnte der Stopp-Helfer einen fremden Prozess signalisieren. Fix: Prozessidentität wird geprüft. Commit 71ed081b.
- L-31 (17.10.) Die Firefox-Runtime wurde ohne Artefakt-Authentifizierung installiert. Fix: Heruntergeladene Artefakte werden authentifiziert. Commit 402c6f10.
- L-32 (17.10.) Der Uninstaller nahm Profilnamen als Eigentumsnachweis für root-Löschungen. Fix: Eigentum wird vor dem Löschen verifiziert. Commit bcb4eda8.
- L-33 (17.10.) Der Diagnose-Sammler schrieb über einen vorhersagbaren /tmp-Pfad. Fix: Schutz gegen Symlinks und Überschreiben. Commit d4e40ad6.
- L-34 (17.10.) Das Support-Bundle folgte Diagnose-Symlinks in beliebige Dateien. Fix: Symlink-Traversal unterbunden. Commit a2de4d01.
- L-35 (17.10.) Die Statistik-Authentifizierung war ohne Token offen. Fix: Ohne gültigen Token antwortet die Seite mit HTTP 503. Commits 3499b013, 0a52590e, 1b81a589.
- L-36 (17.10.) Ein WireGuard-Profil konnte sich nach der Hook-Prüfung und vor dem privilegierten Import ändern. Fix: Import an verifizierte Snapshots gebunden; die verbleibende Grenze ist in docs/security/L-04.md dokumentiert. Commit 9944ce14.

Bewusst akzeptierte Restrisiken

- M-03 VPN-Profil löschen: Der Angriff setzt einen Prozess desselben Benutzers voraus, der ohnehin wirksamere Wege hat. Der Dialog zeigt den echten Zielnamen, das Ziel bleibt auf /etc/wireguard/*.conf begrenzt, und ein gelöschtes Profil öffnet keinen Verkehr. Neu zu bewerten, falls die Slot-Datei für andere Benutzer schreibbar wird.
- M-08 curl-Ausgabe unbegrenzt: Die Last ist zeitlich begrenzt (3 bis 5 Sekunden), läuft im Hintergrund und wird danach freigegeben; die Angreifer müssten auf dem Netzweg sitzen. Messung: 119 MiB Ausgabe, rund 357 MiB Spitzenspeicher bei etwa 40 MiB/s. Die automatischen IP- und Länderabfragen sind seit 9f788603 auf 4 KiB gedeckelt.
- L-01 Kurzer Statistik-Token: Der produktive Token ist ein zufällig erzeugter Wert mit 64 Zeichen (etwa 256 Bit) nach dem dokumentierten Vertrag. Es gibt keinen schwachen Standardwert; ohne gültigen Token antwortet die Seite mit HTTP 503.

Querschnitts-Härtungen

- Vertrauenswürdige Programmpfade statt PATH für sudo, nmcli, Nmap, rkhunter und Wartungswerkzeuge.
- Kein Folgen von Symlinks: Dateioperationen über Verzeichnis-Deskriptoren mit O_NOFOLLOW und O_EXCL bei Importen, Vor-Quarantäne, Logs und Release-Staging.
- Ressourcengrenzen für Byte und Zeit: Parser in begrenzten Worker-Prozessen (PDF, DOCX, CSV, XLSX), Radio, projectM, Updates, OpenAI, ClamAV, Paketmitschnitt.
- Netzwerkziele nur öffentlich bzw. per HTTPS mit gepinntem Origin.
- Release-Kette: Snapshot des gepinnten Commits, Receipt-Bindung, Ablehnung von Symlinks, authentifizierte Manifeste und Upload-Bäume.
- Datenschutz: ein gemeinsamer Schwärzungsfilter für Logs, Diagnose und KI-Übergaben; private Logrechte.

Verifikation

Prüfung	Ergebnis
Fix-Commits im Zeitraum 17.10. bis 13.11.2026	99, alle mit Änderungen an Tests
Neue Regressionstests der Fixes vom 13.11.	123 (Firewall 34, KI-Schwärzung 59, Vor-Quarantäne 13, Text-Import 6, HTTPS-Abfragen 11)
Gegenprobe gegen den Code vor dem Fix (13.11.)	Die Verhaltenstests schlagen mit dem alten Code fehl
black und ruff	sauber für alle geänderten Dateien
Betroffene bestehende Testdateien	keine neuen Fehlschläge gegenüber dem Stand vor dem Fix
Vollständige Testsuite	in dieser Runde nicht ausgeführt, siehe Prüfgrenzen

Prüfgrenzen

- Die Bewertung ist statisch mit gezielten Reproduktionen; Live-Hosting, Hoster-Ratenbegrenzung und produktive PHP-Konfiguration wurden nicht geprüft.
- Die vollständige Testsuite wurde nicht ausgeführt, weil sie in die echte Benutzerumgebung schreibt. Geprüft wurden alle Testdateien mit Bezug zu den geänderten Stellen.
- In der Testumgebung bestehen bekannte Umgebungsfehler (Rechte des Temp-Verzeichnisses, fehlendes NETMON_TEST_ISOLATED, Bildschirmaufnahme unter X). Sie treten vor und nach den Fixes identisch auf

und sind keine Regressionen.

Offene Empfehlungen

- Der IP-Hash der Download-Statistik ist ein ungesalzener SHA-256-Wert und damit für IPv4 rückrechenbar. Empfehlung: IP vor dem Hashen kürzen (IPv4 /24, IPv6 /48) oder HMAC mit eigenem Server-Geheimnis. Nicht dringend, da Statistik und Datenordner geschützt sind.
- run_cmd puffert Prozessausgaben weiterhin ohne Byte-Grenze; für künftige Remote-Abfragen eine begrenzte Variante verwenden.
- Testumgebung bereinigen: Ein Test in test_netmon_vpn_slots und test_netmon_ipv6_ui ruft über nm_ownership.verified_interface echtes sudo auf und wird vom Hostzugriffs-Schutz abgebrochen; hier fehlt ein Test-Fake.

Einordnung

Runde 13 ist eine Code-, Paket- und Release-Prozessprüfung auf Basis automatisierter Scans mit manueller Nachprüfung. Sie ersetzt keinen unabhängigen Penetrationstest und garantiert keine vollständige Fehlerfreiheit. Die Ergebnisse gelten für den genannten Codestand und müssen nach sicherheitsrelevanten Änderungen neu bewertet werden.